

COMPLETE PRODUCT PLAN

From technical sandbox prototype to validated, launch-ready SaaS

Purpose: A complete phased plan for building, proving, operating, and launching the product. It separates verified code from market hypotheses so we never mistake a feature for customer value.

Field	Current truth
Current product	AI-agent action governance control plane for high-consequence actions
Current maturity	Technically validated sandbox prototype; not market validated and not production launch-ready
Working branch	codex/unverified-working-tree-20260917 (no merge to main without founder approval)
Plan version	V1 - 17 September 2026
Owner	Priyank Narola

The non-negotiable principle

We will not call the product complete because screens exist. Completion requires a selected buyer problem, demonstrated technical controls, verified operations, a real pilot, and evidence that customers value and will pay for the result.

1. Executive direction

The product should become a narrow, trustworthy control layer for consequential actions proposed by existing AI agents or workflows. It should not become a generic chatbot, generic AI-agent builder, or a broad support automation platform.

Working thesis: When an AI system proposes a costly or irreversible action, the company needs a separate system that can bind the exact intent, apply policy, require the right approval, execute safely, and prove what happened afterward.

What exists today

- A sandbox-only governance gateway: identity and delegation checks, deterministic risk, deterministic policy, approval workflow, payload integrity, TOCTOU revalidation, execution ledger, audit trail, observability, and reconciliation foundations.
- A demonstrable \$25,000 wire-transfer scenario with separation of duties and full sandbox audit evidence.
- A provisional customer-remediation pilot hypothesis for policy-governed refunds and account credits; disabled-by-default connector boundaries only, with no live credentials or customer data.

What is not proven

- The buyer, their urgent workflow, willingness to pay, and an independent control gap that native platforms do not already solve.
- Production operations: deployed identity provider, real tenant onboarding, monitored infrastructure, support operations, privacy/legal readiness, and real connector behavior.

Definition of 100%

100% does not mean an infinite feature list. It means every launch gate in Phase 10 is satisfied for one defined market wedge. New ideas become backlog candidates, not reasons to delay launch forever.

2. Product definition and boundaries

Item	Decision / rule
Core job	Govern an exact proposed action before it reaches a consequential external system, then retain evidence of its outcome.
Primary user	Operations, risk, security, finance, or support-operations leader responsible for AI-enabled write actions.
Daily user	Operator/requester, distinct approver, policy author, auditor, and administrator.
Initial candidate wedge	Cross-system customer credits, refund exceptions, subscription/entitlement exceptions, or another customer-validated consequential action.
Non-goal	Do not replace CRM, payment, helpdesk, ERP, IAM, or agent platforms. Integrate beside them only after customer evidence.
Safety boundary	No real money or production write operation until an approved connector, customer pilot, credentials, rollback/recovery policy, and deployment gate exist.

Competitive position to test

Existing platforms can already automate refunds, approvals, CRM actions, and agent workflows. The potential differentiation is independent, portable authority control and evidence across systems - not merely offering the same workflow inside one vendor platform.

Explicitly deferred

- Generic agent builder, generic RAG/chatbot, prompt filtering product, universal workflow automation, dynamic MCP discovery, multi-region infrastructure, broad connector catalog, visual policy designer, and new canned demos.
- Any external communication, real-customer data, live payment, production deployment, commercial terms, or merge to main without required founder approval.

3. Complete product experience

Every production capability must be owned by a user journey, an API contract, a policy boundary, audit evidence, tests, and operations documentation.

Persona	Primary job	Must be able to do
Administrator	Set up a tenant securely	Manage identity provider, tenant settings, roles, agent/tool registry, retention, and emergency access.
Policy author	Describe acceptable action boundaries	Author/review/version policy rules, thresholds, approval requirements, exceptions, and simulation results.
Requester / AI agent	Propose a specific action	Submit minimum necessary context, receive a decision, see clear remediation when blocked, and never self-approve.
Approver	Make a high-stakes decision	Review exact intent, facts, policy, risk, history, impact and recovery plan; approve/reject/expire with reason.
Operator	Resolve failed or uncertain execution	See provider receipt, reconcile outcomes, escalate safely, and create a correction action where permitted.
Auditor / security	Prove controls worked	Search immutable event history, export evidence, inspect policy/version/actor context, and identify anomalies.

Required user journeys

- Onboard tenant and configure verified identity, roles, domains, data retention, and API/MCP credentials.
- Register agent, delegated authority, tool, action, resource, risk tier, and policy scope.
- Preflight an action without persistence; show predicted policy/risk/approval/connector route before an action is submitted.
- Submit a bound action; receive allow, block, or approval requirement with understandable reasons and stable idempotency behavior.
- Approve or reject with separation of duties, expiry, revalidation, and immutable event evidence.
- Execute through an approved connector or sandbox; receive a provider receipt, terminal outcome, and correction/reconciliation workflow.
- Search and export evidence for an action, agent, policy, approver, tenant, outcome, or time window.

4. Architecture plan

The architecture is deliberately layered so an AI provider or downstream connector can never bypass deterministic authorization.

Layer	Required responsibilities
1. Entry	REST and MCP endpoints; authenticated caller; rate limits; idempotency; schema validation; correlation ID.
2. Security context	Resolve principal, tenant, agent, roles and delegation server-side. Never trust caller-selected tenant, policy, risk, or approver.
3. Action contract	Bind exact action, resource, normalized parameters, payload digest, context references, recovery classification, and minimum data.
4. Governance engine	Deterministic risk, policy evaluator, advisory intelligence, limits, separation of duties, approval rules, and block reasons.
5. Approval engine	Time-bounded approvals, independent approver, full revalidation at decision time, concurrency protection, and terminal state machine.
6. Execution boundary	Sandbox by default; connector interface; provider idempotency; timeouts; unknown outcome handling; no automatic consequential retry.
7. Evidence and operations	Append-oriented audit chain, execution ledger, export, reconciliation queue, metrics, tracing, alerting, retention/deletion.
8. Product UI	Control center, guided action workflow, approval workbench, policy management, evidence search, operational queue, settings.

Data model requirements

- Tenant-owned principals, agents, tools, actions, resources, delegations, policies, policy versions/rules, requests, decisions, approvals, audit events, execution attempts, provider receipts, and reconciliation cases.
- Immutable identifiers, actor provenance, timestamps with UTC timezone, causal sequence, payload digest, trace ID, idempotency key, policy version, and retention classification.
- PostgreSQL is authoritative. SQLite is useful for unit speed but never the proof for production concurrency, locking, migration, or tenant isolation.

5. Functional blueprint - every release domain

Domain	Complete capability checklist
Identity and tenant	OIDC/OAuth provider integration; MFA/SSO policy; tenant setup; server-derived scope; SCIM only when customer evidence demands it; break-glass audited access.
Roles and authority	Admin, policy author, approver, operator, auditor; least privilege; delegation issuance/revocation/expiry; separation of duties; entitlement reviews.
Agent registry	Agent identity, owner, status, risk class, allowed tools/actions/resources, lifecycle (activate/suspend/retire), credentials and rotation.
Action contracts	Typed action schemas; parameter validation; amount/currency/limit controls; context references; data minimization; idempotency; digest binding; recovery classification.
Policy	Deterministic versioned rules; thresholds; scopes; approval chains; exceptions; dry-run/simulation; explainability; policy-change audit and rollback.
Risk and intelligence	Deterministic signals are authoritative. Model inference is advisory only, has provider fallback, provenance, evaluation corpus, drift monitoring, and cannot execute or approve.
Approvals	Work queue, full context, distinct approver, expiry, reject/approve reason, delegation checks, revalidation, concurrency safety, notifications only after customer demand.
Execution and connectors	Sandbox first; explicit connector routes; provider idempotency; signed webhooks; timeout/unknown state; receipt parsing; rate limits; no hidden retries.
Reconciliation and remedies	Operator queue for failed/unknown outcomes; evidence-based resolution; correction action rather than pretending irreversible operations can be reversed.
Evidence and audit	Causal sequence, append-only events, filters, exports, integrity checks, retention/deletion controls, audit-ready human-readable timeline.
Operations UI	Dashboard, requests, approvals, policies, agents, tools, delegations, observability, reconciliation, launch readiness, tenant settings.
Admin and support	Tenant support boundaries, data deletion/export, consent/retention controls, incident workflow, status page, runbooks, feature flags.

6. Security, privacy, and reliability plan

Control area	Release requirement
Authentication	Production REST and MCP callers must authenticate. Development tokens are development-only. No known development verifier in hosted environments.
Authorization	Server-derived principal/tenant/role/delegation; tenant isolation at API, service, repository, and database layers; deny by default.
Action integrity	Canonical payload digest at submit and revalidation at approve/execute; idempotency and state-machine guards; tamper events.
Secrets	Secret manager, environment separation, rotation policy, no secrets in logs/source/demo data, dependency scanning, least-privilege connector scopes.
Webhooks	HMAC or asymmetric verification, replay window, durable dedup, dead-letter/reconciliation visibility, provider-specific event validation.
Data handling	Data minimization, PII inventory, retention/deletion schedule, encrypted transit/storage, tenant export/delete process, no payment-card data.
Availability	Health/readiness checks, monitored dependencies, database backups and restore rehearsal, migration rollback plan, capacity and failure-mode tests.
Audit	Immutable event semantics, causal ordering, correlation IDs, actor provenance, export verification, access logs, periodic integrity review.
AI safety	Model is advisory only; evaluated prompts/corpus; prompt and provider failure fallback; no model-controlled policy/approval/execution paths.
Incident response	Severity definitions, owner/on-call model, customer communications templates, connector disable switch, evidence preservation, post-incident review.

Non-functional release targets

- Define p95 latency/error budgets per action class; no generic target without pilot workflow and provider baseline.
- Accessibility: keyboard-complete critical workflows, focus management, semantic labels, contrast, screen-reader testing, and error messages that explain recovery.
- Localization/time: UTC storage, clear local display, money/currency formatting, audit timestamps that retain source and display time zones.
- Observability: structured logs, traces, metrics, audit correlation, alert thresholds, and data-redaction tests.

7. Delivery phases and completion evidence

Phases are sequential where evidence matters. Engineering can overlap internally, but a later phase cannot be called complete until its predecessor's gate is met.

Phase	Name	Work	Completion evidence
0	State and baseline	Preserve main; audit branch; reconcile docs, tests, migrations, security controls, and known debt.	Verified branch, reproducible local environment, evidence ledger, no false completion claims.
1	Problem discovery	Interview target buyers; map current workflow, authority, failure cost, native controls, recovery path, and buying process.	15 interviews or a deliberate stop/pivot based on strong disconfirming evidence; scorecard completed.
2	Wedge decision	Choose one buyer, one painful action, one measurable outcome, one integration boundary, and one initial price hypothesis.	Founder-approved one-page wedge decision; rejected alternatives recorded.
3	Pilot contract	Define pilot success, data boundary, sandbox/test mode, stakeholders, security questionnaire, rollout/rollback, support and commercial assumptions.	One design partner or committed pilot path; no production data until approved.
4	Pilot product	Build only capabilities needed for selected workflow: identity, tenant roles, action contract, policy, approval, connector, receipt, reconciliation, evidence.	Pilot acceptance tests pass against approved test environment and user workflow.
5	Production foundation	Real Postgres migration/restore drill; deployed auth; secrets; monitoring; backups; operational runbooks; legal/privacy/support groundwork.	Release checklist, rollback rehearsal, security review, SLO/alert evidence, owner sign-offs.
6	Private beta	Onboard 2-5 design partners in constrained mode, observe tasks, resolve defects, validate time/cost/risk improvement, price/test packaging.	Usage evidence, support learnings, retention/renewal signal, zero unresolved critical control defects.
7	Launch	Finalize positioning, pricing, onboarding, documentation, security/compliance posture, sales demo, support, website, and release communications.	Launch gates in Phase 10 signed; metrics dashboard live; go/no-go decision.
8	Scale	Repeatable onboarding, additional evidence-backed connectors, policy templates, enterprise controls, reliability/capacity maturity.	Expansion only from measured demand and operational capacity.

8. Current status mapped to the phases

Phase	Current status	Next action
0 - State and baseline	In progress and materially advanced. Review branch has verified hardening and documentation reconciliation; main remains untouched.	Continue permitted verification, test, security, documentation, and accessibility/reliability work only.
1 - Problem discovery	Not started as customer evidence. Research documents exist, but 0 interviews, 0 responses, 0 pilots, and 0 WTP evidence.	Founder approval is required before outreach; then conduct interviews without selling features as facts.
2 - Wedge decision	Not decided. Customer remediation is a provisional review-branch hypothesis, not a final company decision.	Select only after discovery evidence and competitor-gap analysis.
3 - Pilot contract	Preparation documents exist; no approved pilot partner, external account, or live data boundary.	Obtain explicit permission, then create a scoped pilot agreement/process.
4 - Pilot product	Sandbox components are partly built; customer-specific workflow/connector must not be assumed.	Build the smallest validated path after Phase 2-3.
5-8	Not started; cannot be truthfully completed by code alone.	Run only after validated wedge, pilot authority, and operating commitments.

Important: A code sprint can improve the technical baseline by 19 September 2026. It cannot truthfully complete customer validation, legal readiness, pilot evidence, or production operations without real external inputs and founder approvals.

9. Workstream roadmap - no missing ownership

Workstream	Required outputs
Product	Buyer/problem narrative, wedge decision, PRD, acceptance criteria, prioritization, pricing hypotheses, metrics.
Discovery	Interview recruitment, script, notes, evidence scorecard, competitor proof, objection analysis, pivot/continue decision.
Design/UX	Information architecture, critical-flow prototypes, content design, approval confidence, accessibility, usability tests.
Backend	Action gateway, policy/approval, connectors, audit/reconciliation, tenancy, migrations, APIs, background jobs when justified.
Frontend	Control center, action flow, approval desk, policy views, evidence explorer, admin and error/empty/loading states.
AI/Intelligence	Advisory models, evaluation set, signal provenance, guardrails, cost/latency observability, deterministic fallback.
Security	Threat model, authZ tests, secrets, supply chain, penetration test scope, incident response, audit controls.
Quality	Unit/API/integration/E2E/accessibility/load/failure-mode/migration/restore tests; release sign-off matrix.
Platform	Containers, CI, managed Postgres, IaC, backups, observability, deployment/rollback, environment isolation.
Legal/privacy	Terms, privacy notice, DPA, subprocessors, data map, retention/deletion, security questionnaire, compliance roadmap.
Go-to-market	Positioning, ICP, pricing, pilot offer, demo, website, outbound only after approval, sales/support collateral.
Customer success	Onboarding, training, support channel, success plan, usage reviews, incident communications, renewal expansion.

10. Test and release-quality plan

Test layer	Required proof before launch
Unit	Risk, policy, action schemas, money validation, digesting, state transitions, recovery classification, connector mapping.
API/service	AuthN/AuthZ, tenant isolation, delegation, SoD, idempotency, policy version, expiry, revalidation, error semantics.
Database	PostgreSQL migrations, fresh and upgrade paths, FK/constraints, locks, concurrent approval/execution, backup/restore.
Connector	Test-mode provider receipts, webhook signature/replay/dedup, timeout, partial failure, unknown outcome, no duplicate charge/refund.
Frontend	Critical browser E2E: login, submit, approve/reject, evidence search/export, reconciliation, admin errors; responsive and accessibility checks.
Security	SAST, dependency scan, secret scan, auth bypass, IDOR, CSRF/CORS, rate limit, malformed payload, privilege escalation, audit tamper tests.
Reliability	Load/soak, queue/backpressure where present, provider outage, database failover, rollback, recovery runbook exercise.
AI evaluation	Adversarial prompts, false-allow/false-block analysis, provider failure, drift/cost/latency, advisory-boundary proof.
Usability	Task success for requester/approver/operator/auditor; time-to-decision, confusion points, policy explanation comprehension.

Current verified baseline

Review branch backend suite: 391 passed, 8 skipped, 1 upstream warning; frontend typecheck, lint, and 21-route production build previously pass. This is useful technical evidence, but it is not a production E2E, customer, or market-validation certificate.

11. Launch gates - the real definition of done

Gate	Evidence required
Customer value	One ICP, one buyer, one urgent action, quantified baseline, repeated evidence, clear reason native tools are insufficient.
Commercial	Pilot offer, pricing logic, procurement path, agreement process, success metrics, case-study permission approach.
Product	Core journey completes without founder intervention; policy and recovery are understandable; no P0/P1 defects.
Security	Threat model reviewed; production authZ proven; secrets/tenancy/audit controls tested; security response process exists.
Privacy/legal	Data map, privacy notice, DPA/terms, retention/deletion, subprocessor list, incident commitments reviewed.
Reliability	Managed database, backup/restore rehearsal, monitoring/alerts, incident/on-call ownership, deploy/rollback drill.
Integration	At least one selected connector proven in customer-approved test mode with idempotency, receipts, webhook/reconciliation and kill switch.
UX/accessibility	Critical tasks tested with real users; keyboard and screen-reader baseline; help and errors make recovery possible.
Support	Onboarding, support channel, known limitations, escalation path, status communication, operator runbooks.
Founder governance	Explicit approval for pilot, external exposure, communication, financial/legal commitments, and any merge/release.

Launch rule: If any gate lacks evidence, the status is 'not ready' or 'private pilot only' - never 'production ready.'

12. Metrics and decision dashboard

Metric family	Measures
Discovery	Interviews completed, ICP match rate, repeated pain frequency, workflow volume, cost of failure, willingness-to-pay signal, pilot conversion.
Product value	Actions governed, avoided/recovered error, approval turnaround, policy explanation comprehension, operator time saved, evidence export use.
Safety	Unauthorized attempts blocked, tamper detections, SoD violations prevented, stale delegation blocks, unresolved unknown outcomes, audit integrity failures.
Reliability	Action decision latency, execution success, provider timeout/unknown rate, reconciliation time, incident count, backup/restore success.
Commercial	Qualified pipeline, pilot starts, activation, weekly active operators, retained accounts, conversion, ARPA, gross retention, expansion.

Early decision rules

- Continue: multiple target buyers describe the same recurring action-control gap and agree to a scoped pilot or paid design partnership.
- Refine: pain exists but the action, buyer, connector, or value metric differs from the current hypothesis.
- Pivot: native platform controls are sufficient, no buyer owns the risk, or the workflow is too infrequent/low-cost to support a product.
- Stop: no credible evidence of urgency or willingness to test after the planned discovery set; do not hide this with more features.

13. Immediate execution plan

Priority	Next permitted work	Output / evidence
P0	Finish review-branch verification, security fixes, test coverage, documentation reconciliation, accessibility/reliability checks.	Commit-backed milestones only; no merge to main.
P0	Keep the canonical state record and pending permissions list accurate.	No drift between documentation, source, tests, and Git history.
P1	Prepare discovery materials: interview guide, scorecard, safe demo narrative, competitor-gap hypotheses, consent/data boundaries.	Ready-to-send materials; no outreach until founder approval.
P1	Audit pilot proposal against native support/payment controls and clarify independent evidence/control gap.	Evidence-backed wedge decision input, not a claim of differentiation.
Blocked	Customer outreach, external hosting, live credentials/data, payments, contracts, account creation, publishing, or merge to main.	Requires explicit founder approval and a scoped plan.

Founder decisions required

- Approve customer-discovery outreach and the exact target profile/message before any message is sent.
- Approve external/customer-hosted exposure, selected pilot environment, identity/tenant design, and any credential use.
- Approve a merge from the review branch to main after reviewing commit-backed verification evidence.

Working cadence

Every cycle: inspect the current branch and state record; choose the highest-risk permitted item; implement or verify it; run proportionate checks; commit only verified work; update the record; report the exact commit. No feature expansion is silently smuggled into a verification cycle.

Appendix A. Build checklist by release

Release	Checklist
Foundation	Repository reproducible; CI green; code ownership; architecture and threat model; migration chain; canonical state record.
Pilot-ready	Chosen ICP/workflow; OIDC; tenant roles; scoped connector; sandbox/test mode; policy templates; audit/export; reconciliation; E2E path.
Private-beta	Real test tenant; monitoring; support/onboarding; backup/restore; performance baseline; privacy/data controls; defect triage; weekly customer review.
Launch	Validated value + price; production deployment/rollback; security review; legal documents; public docs/site; support SLA; analytics; go/no-go log.
Scale	Repeatable onboarding; self-serve or assisted implementation; paid conversion; capacity controls; connector roadmap evidence; enterprise operations.

Appendix B. Status vocabulary

Label	Meaning
Complete	Implemented, proportionately verified, committed with exact hash, and accepted within scope.
In progress	Work exists but lacks commit-backed verification or a completed gate.
Hypothesis	Plausible product/market claim that has not been proven by customer evidence.
Blocked	Needs a founder decision, external authorization, customer input, credential, contract, or production environment.
Not applicable	Intentionally excluded from the current selected wedge/release; not silently forgotten.

Source of truth

This plan was prepared from the current repository state, especially AGENTOS_STATE.md and the product-discovery records. If a future decision conflicts with this plan, update the state record and version this document rather than rewriting history.